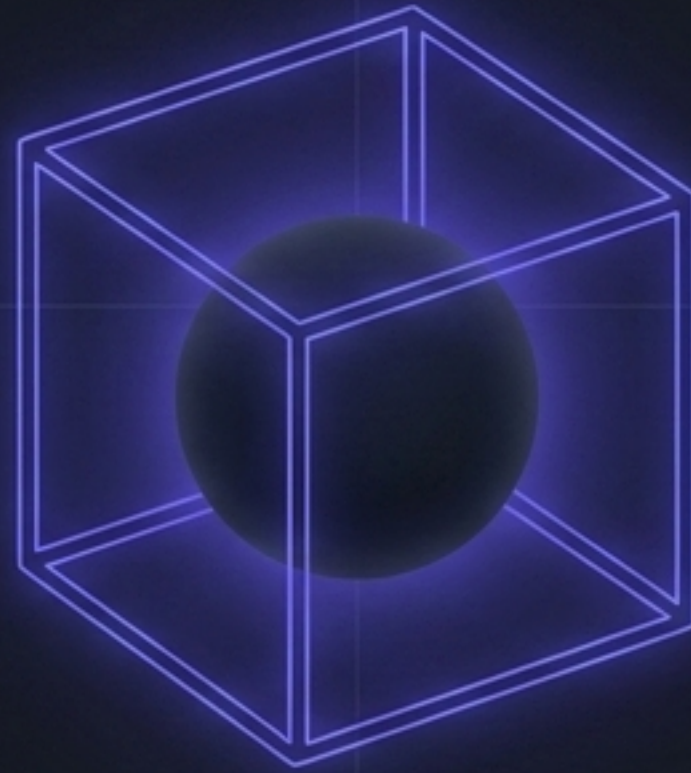


Securing the Agentic Frontier

A Blueprint for Velocity, Trust, and Sovereign AI Systems

```
function AgenticDriver() {  
  script.Login.LastLogin( => => {  
    System.out.printf("Welcome to the frontier: %s",  
      "agentas")  
  });  
}
```



```
// +function 1/1  
export static view SferoApplications {  
  staticResults = {  
    console.log('States')  
    System.out.println('I am process');  
    if (emjee) {  
      System.out.println('For altay code');  
    }  
  }  
}
```

Portfolio & Thesis by RMD26 (Róbert Málík)

THE ACCELERATION

82%

Developers using AI coding assistants daily/weekly.

59%

juggle three or more AI tools in parallel.

THE DEFICIT

28%

Confidence that AI-generated code is actually secure.

76%

experience frequent hallucinations or outright AI mistakes.

AI adoption is ubiquitous. Trust is practically non-existent.
High velocity without integrated trust is an organizational liability.

THREAT RADAR

HALLUCINATED DEPENDENCIES

Up to **21%** of dependencies generated by AI link to non-existent open-source libraries.

Attack Vector: Threat actors monitor AI outputs and create malicious packages matching phantom names (advanced typosquatting).

LEGACY WEAKNESSES

AI models reproduce the flaws of their training data.

Key CWEs: Memory corruption (Buffer overflows, out-of-bounds reads) and Injection (SQL, XSS).

INSECURE DEFAULTS

AI frequently omits security controls unless explicitly prompted.

Example: Generating database queries with direct user input concatenation instead of parameterized queries.

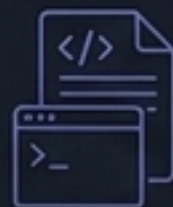
<< FLOW: INJECT >>

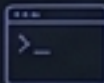
| USE: RAW_INPUT |

| USE: RAW_INPUT |

-> {pkg_name} ? 404

Phase 1: Generative Copilots (Current)

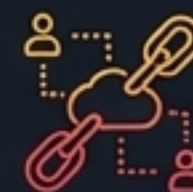


Property	Description
Mechanism: 	Passive. Responds to developer prompts.
Output:	Code snippets, scaffolding.
Risk Profile:	Code-level vulnerabilities (CWEs) reviewed by humans.



Evolutionary Shift

Phase 2: Agentic Systems (Emerging)



Property	Description
Mechanism: 	Autonomous. Initiates tasks, chains tools, executes logic without constant prompting.
Impact: 	By 2027, 80% of engineers will need to upskill for agentic architecture (Gartner).
Risk Profile: 	The OWASP Agentic Top 15. Risks include agent chaining privilege escalation, memory poisoning, and cascading trust failures.

THE SPHERE

The Raw Intelligence:
The dark, powerful, opaque
sphere represents Artificial
Intelligence.

It is dynamic, rapidly
evolving, and inherently
non-deterministic. It moves
at breakneck velocity.



THE WIREFRAME CUBE

The Guardrails:
The structured, transparent,
rigid cube represents
Adaptive Security &
Governance.

It safely contains the sphere,
providing visible boundaries,
compliance parameters, and
control points.

**We cannot slow down the sphere.
We must build a stronger, smarter cube.**

Early (Shift Left)

Assess code instantly.

Deploy AI-aware SAST and SCA tools inside the IDE before the commit.

Explainable (Context)

AI remediation must provide human-readable logic.

Map fixes to CWE references so developers understand why the AI generated the fix, building trust.

AI Dev Trust

Security cannot break the flow state.

Integrate directly into native workflows (IDE, Pull Requests) to ensure developer adoption.

Experience (Frictionless)

THE IDE (Code Creation)

THE THREAT:

Insecure real-time suggestions accepted instantly.



THE GUARDRAIL:

Real-time linting and in-IDE scanning. Prevent insecure logic from ever leaving the local workstation.



THE PULL REQUEST (Code Review)

THE THREAT:

17% of PRs contain critical-severity security issues. AI floods reviewers with volume.



THE GUARDRAIL:

AI-powered, context-aware diff analysis and dynamic risk scoring based on developer role and code criticality.



THE REPOSITORY (Post-Merge)

THE THREAT:

Post-merge creep and unvetted AI code accumulating in production.



THE GUARDRAIL:

100% continuous scanning coverage. No code ships without an automated audit.



Outdated Governance (Static)

> _

Policy

One-size-fits-all rules (e.g., 'Block all AI code').

Result

Developer friction, bypass behavior, stalled velocity.

Tracking

Spreadsheets, manual audits.

Adaptive Governance (Dynamic)

\$ █

Policy

Contextual Risk Scoring. Low-risk code (test scaffolding) auto-merges; high-risk code (crypto/auth) triggers mandatory human review.

Result

Proportionate controls, maintained velocity.

Tracking

The AI-BOM (Bill of Materials). An automated, real-time inventory of all LLMs, fine-tuned adapters, agents, and prompt libraries in the ecosystem.

From Theory to Practice

Frameworks mean nothing without execution. The following platforms—Sovereign Architect and Slovenský Copilot—demonstrate how RMD26 applies adaptive guardrails, agentic orchestration, and strict compliance to live development environments.

[APP_1]: Sovereign Architect

[APP_2]: Slovenský Copilot

Sovereign Architect

Agentic Grant Intelligence & Compliance Workspace

A Next.js platform that leverages AI agents to parse, evaluate, and draft EU/US grant proposals, while simultaneously running automated, real-time compliance checks on the underlying data.

METRIC 1

[SUCCESS_RATE]: 32%

METRIC 2

[AVG_FIT_SCORE]: 78%

METRIC 3

[TRACKED_CALLS]: Horizon
Europe, NSF, Digital
Europe

System Architecture

Layer 1: The Client (Frontend UI)

Stack List: Next.js 14 App Router, React 18, Tailwind CSS (bg-slate-950).

MODULES:

Modules: /dashboard, /explorer, /proposals, /compliance

Layer 2: The Orchestration Layer (API Routes)

NODE 1:

Node 1: /api/grants/search: Dynamic indexing of global grants.

NODE 2:

Node 2: /api/grants/evaluate: Agentic fit-scoring and explanation generation.

Layer 3: The Intelligence Engine

Multi-model API integrations (Fireworks, OpenAI, Groq) feeding into the `mockData.ts` simulation engines for `resilient testing`.

COMPLIANCE RADAR MATRIX

Vector	Status Badge	Detail
AI Act Classification	[ATTENTION]	System falls under high-risk category for public sector decision support.
Data Residency	[WARNING]	Primary storage in EU; US read-replicas for analytics only.
State Aid / De Minimis	[WARNING]	--- //[EMPTY]
Procurement Rules	[OK]	Framework contract vs. open call route cleared.

Slovenský Copilot

(Project SKNICVP26_017)

The Author

Róbert Málik. Brings 6 years of deep IT Helpdesk experience and 3 years of Infrastructure Administration (CompTIA A+, ITIL) into the prompt engineering and architecture of the model.

The Mission

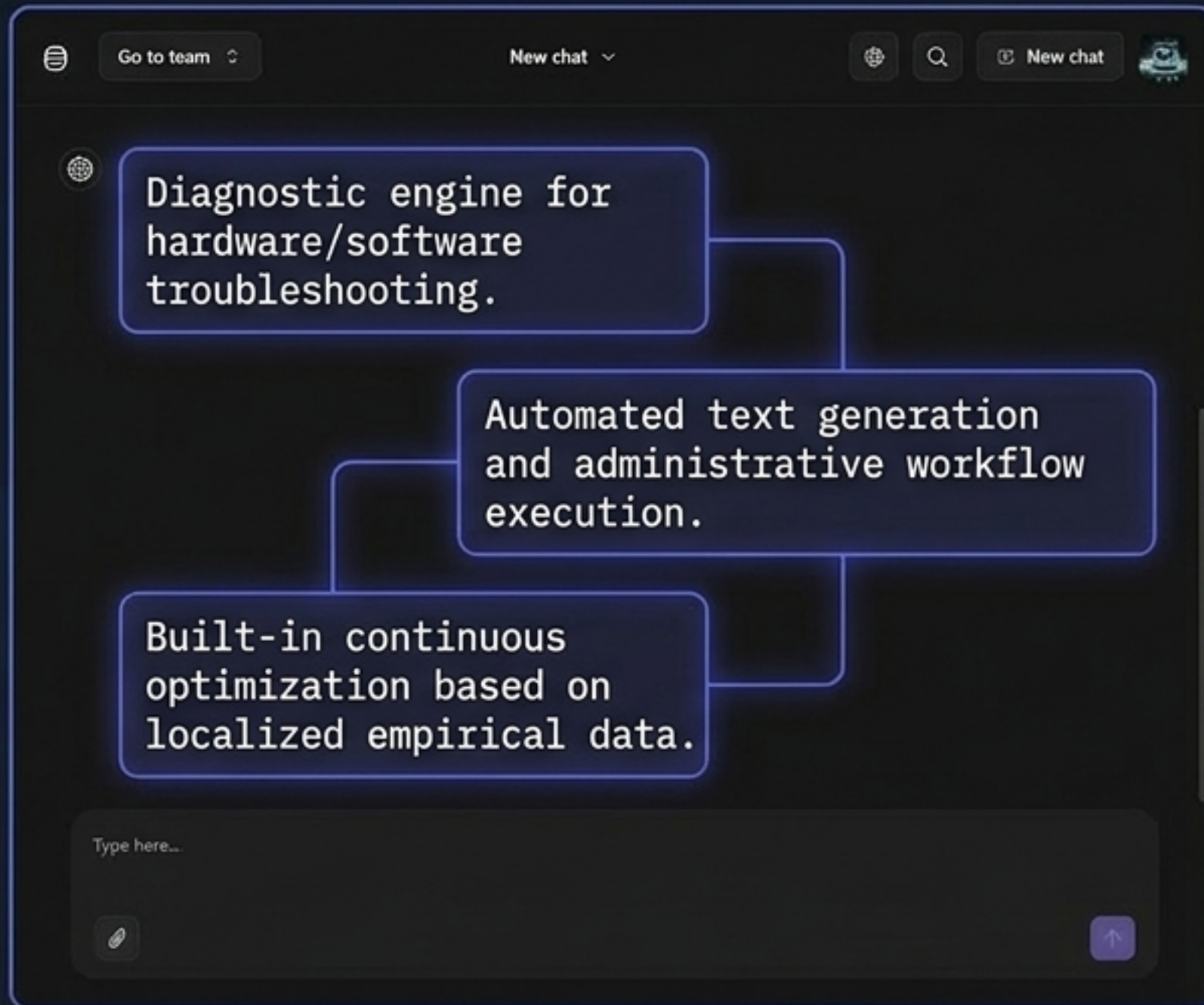
To build a fully localized, intelligent AI assistant optimized for the Slovak language, specifically sandboxed to solve regional IT support, education, and administrative bottlenecks.

The Rationale

Existing global LLMs suffer from language barriers and lack regional context. Slovenský Copilot creates a sovereign, culturally aligned tool to drive local digital transformation.

The Dark-Mode Workspace

Technical Capabilities



Pilot KPIs

TARGET_USERS: **30** verified pilot testers providing structured feedback.

INTERACTION_VOLUME: **500** processed AI interactions during the live phase.

SATISFACTION_RATE: **>80%** baseline metric for prototype utility.

MODULES: **5** fully functional, sandboxed agentic modules deployed.

Aug 01 | Feb | Mar | Apr | May | Jun | Nov | Dec

Analysis & Design

Requirement gathering, architecture design, and defining technical parameters.

Prototype Development

Implementation of core NLP modules, integration, and iterative local testing.

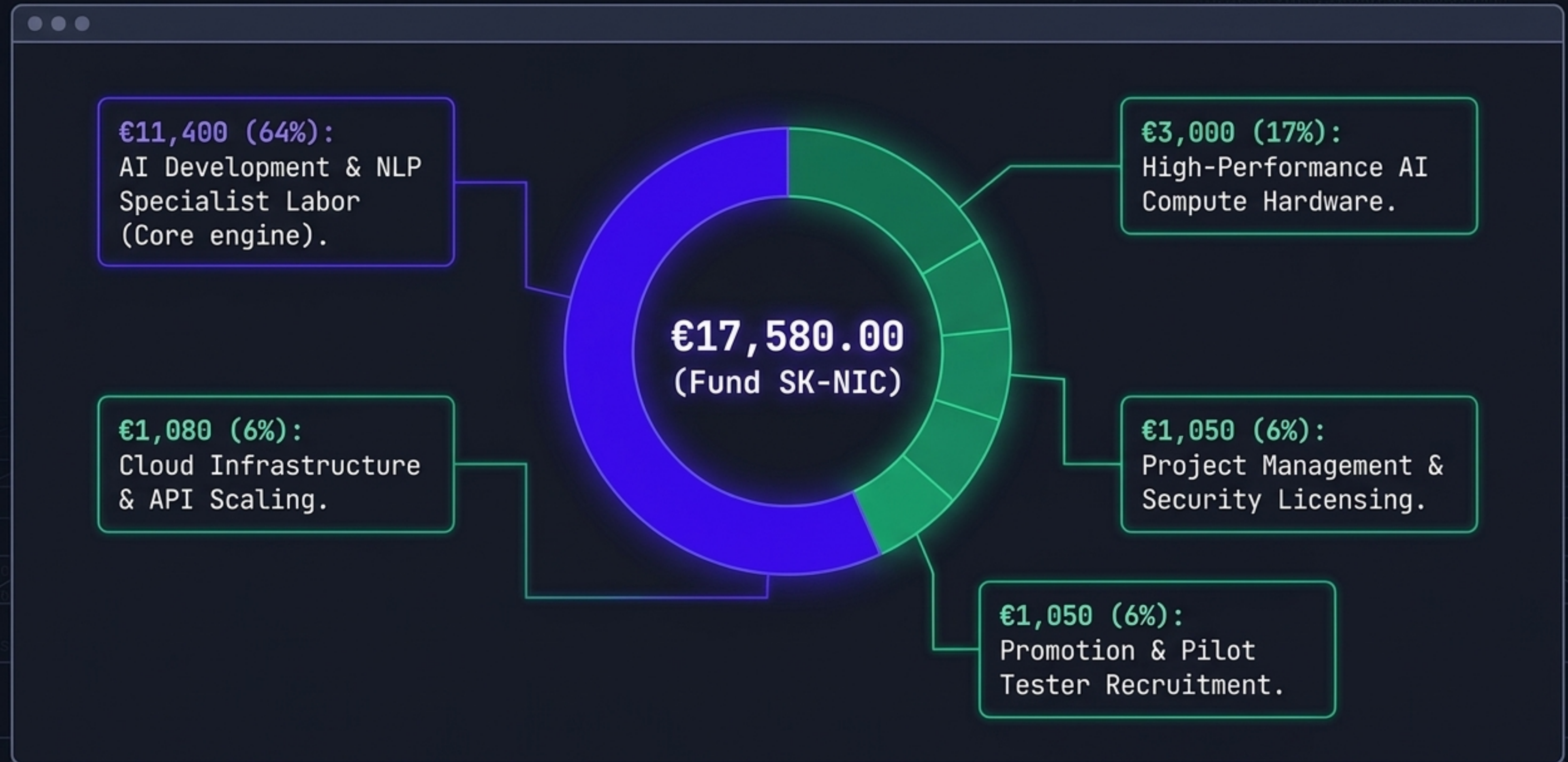
Pilot Deployment

Onboarding 30 testers, tracking the 500 target interactions, and identifying systemic edge cases.

Finalization

Feedback integration, technical documentation, and public deployment of the functional model.

> Budget Allocation Blueprint



The RMD26 Blueprint for 2026

Velocity via Autonomy

Unleashing agentic systems to accelerate development, navigate compliance (Sovereign Architect), and solve local bottlenecks (Slovenský Copilot).

Trust via Guardrails

Implementing the 3 E's (Early, Explainable, Experience) and relying on continuous, contextual risk scoring rather than static bottlenecks.

Sovereignty via Design

Ensuring data residency, localized context, and strict regulatory adherence are built into the architecture, not bolted on after deployment.

The future of software is autonomous. The future of security is adaptive.
We build the cube so the sphere can scale.